

H2 — Fraîcheur de propagation

H2 — Mesure de la fraîcheur de propagation du pipeline HOMO-CI

Hypothèse testée : le délai temporel moyen entre la survenue d'un changement significatif et sa prise en compte dans le dossier d'homologation est ≤ 24 heures, avec au moins 80 % des changements propagés sous 24 heures (T-1.2-FINAL §1.3).

Résumé exécutif

- **n = 24 événements** simulés sur 8 catégories.
- **M2.1 (MTTU) : 13.47 h** IC 95 % [13.47 h ; 13.47 h]
- **M2.2 (P95) : 22.83 h**
- **M2.3 (% < 24 h) : 100.0 %** IC 95 % [100.0 % ; 100.0 %]
- **Facteur d'amélioration vs baseline manuelle : $\times 160$** (baseline = 90 jours = 2160 h).
- **Verdict : H2 confirmée fortement** — $M2.1 \leq 24$ h et $M2.3 \geq 90$ %.

Méthodologie

La mesure adopte un **modèle déterministe complété par Monte Carlo** :

1. Le pipeline HOMO-CI a des **cadences observables** (cf. `injection_protocol.yaml` §`pipeline_model`). Pour chaque catégorie, le délai de propagation Δt est une fonction *déterministe* de l'heure d'injection et des cadences.
2. Un **calendrier de 24 injections** (3×8 catégories) est généré avec `seed=42` (reproductible) sur une fenêtre de 14 jours.

3. Pour chaque événement, Δt est calculé selon le modèle : $\Delta t = (t_{\text{dossier_regen}} - t_{\text{injection}})$ où $t_{\text{dossier_regen}}$ est la prochaine régénération nightly *suivant* la détection par le watcher.
4. L'intervalle de confiance à 95 % est estimé par bootstrap sur 1000 simulations Monte Carlo avec jitter de latence selon une loi gaussienne sur les watchers continus.

Modèle de cadences du pipeline

Catégorie	Type	Cadence	Latence	Description
C1_CVE	scheduled	nightly à 21:00 UTC	5.0 min	Trivy nightly + npm audit sur images Docker
C2_NSg	polling	toutes les 5 min	1.0 min	Azure Activity Log polling toutes les 5 minutes
C3_AD_user	continuous	temps réel	0.5 min	Wazuh agent DC01 stream Security Event 4720
C4_DA_add	continuous	temps réel	0.5 min	Wazuh agent DC01 stream Security Event 4732
C5_Siem_rule	polling	toutes les 60 min	2.0 min	Wazuh manager API horaire
C6_Docker	continuous	temps réel	0.1 min	Docker events watcher en streaming sur web01
C7_SAST	on_push	déclenché par commit	3.0 min	Semgrep CI déclenché par git push (~3 min)
C8_npm_audit	on_push	déclenché par commit	3.0 min	npm audit CI déclenché par git push

Régénération du dossier : nightly à 22:00 UTC, durée 20 minutes.

Résultats par catégorie

Catégorie	n	Δt moyen	Δt médian	Δt max	% < 24 h
C1_CVE	3	13.11 h	13.93 h	23.49 h	100.0 %
C2_NSg	3	15.06 h	14.88 h	19.33 h	100.0 %
C3_AD_user	3	9.42 h	10.56 h	17.12 h	100.0 %
C4_DA_add	3	17.91 h	20.53 h	20.87 h	100.0 %
C5_Siem_rule	3	12.30 h	13.42 h	19.97 h	100.0 %
C6_Docker	3	14.61 h	16.34 h	20.27 h	100.0 %
C7_SAST	3	16.70 h	15.58 h	20.15 h	100.0 %
C8_npm_audit	3	8.62 h	4.01 h	18.09 h	100.0 %

Test statistique vs baseline manuelle

La **baseline manuelle** d'un cycle d'homologation type 2 est de **90 à 180 jours** (revue annuelle ou triennale). Le pipeline HOMO-CI propose une **propagation de 13.47 h** en moyenne.

Le **facteur d'amélioration** sur la borne basse de la baseline est de :

$$\text{Speedup} = \frac{2160 \text{ h}}{13.47 \text{ h}} \approx \mathbf{160 \times}$$

Cette amélioration de plusieurs ordres de grandeur reflète la nature **structurellement différente** de l'approche continue : la propagation automatisée mesure le **temps d'ingestion** des changements, là où la baseline manuelle est dominée par le **cycle de revue formelle**.

Verdict de l'hypothèse H2

- M2.1 = 13.47 h (IC95% [13.47 h ; 13.47 h]) ≤ 24 h ?  OUI
- M2.3 = 100.0 % ≥ 80 % ?  OUI
- M2.3 = 100.0 % ≥ 90 % ?  OUI

Verdict : H2 confirmée fortement — M2.1 ≤ 24 h et M2.3 ≥ 90 %.

Analyse de sensibilité — fréquence de régénération du dossier

La régénération est le **levier architectural majeur** du pipeline. L'analyse suivante mesure son impact sur les trois métriques, à calendrier d'injections constant (seed=42).

Configuration	Intervalle	M2.1	P95	% < 24 h	Δt max
weekly (cycle audit traditionnel)	7.0 j	4.4 j	6.9 j	0.0 %	6.9 j
nightly à 22:00 UTC (référence)	24.0 h	13.5 h	22.8 h	100.0 %	23.5 h
every 12h	12.0 h	7.5 h	23.1 h	95.8 %	25.5 h
every 6h	6.0 h	5.0 h	23.1 h	95.8 %	25.5 h
hourly	1.0 h	2.3 h	20.8 h	100.0 %	23.2 h
every 15 min (real-time)	15 min	1.7 h	20.0 h	100.0 %	22.4 h

Lecture : la régénération **weekly** (cycle audit traditionnel) **n'atteint pas l'objectif H2** (M2.3 = 0 %). La configuration **nightly** (référence) atteint M2.3 = 100 % mais avec une moyenne de 13,5 h. Une régénération **hourly** ramène M2.1 à 2,3 h. En-dessous d'1 heure, l'amélioration se **sature** : la borne basse M2.1 $\approx 1,7$ h est imposée par le **watcher CVE nightly** (le plus lent). Sans accélération de ce watcher, augmenter encore la fréquence de régénération est sans effet.

Insight architectural : le goulot d'étranglement de la fraîcheur est le **watcher le plus lent**, et non la régénération elle-même. Cette observation oriente les optimisations futures : avant de durcir la régénération, accélérer le scan CVE (par exemple toutes les 4 heures plutôt que nightly).

Calibration pilote — vérification empirique sur Azure réel

Pour valider l'**adéquation modèle / réalité**, deux injections réelles ont été conduites sur Azure (catégorie C2 NSG) :

- **I1** : ajout d'une règle de test (priorité 4 000, port 9 999) ;
- **I2** : suppression de la règle ajoutée à I1.

Pour chaque injection, trois horodatages sont mesurés : `t_source` (avant action), `t_azure` (confirmation par Azure ARM), `t_detect` (détection par poll du SDK).

Injection	Δt Azure ARM	Δt détection	Δt total
I1 — create NSG rule	1.74 s	2.99 s	4.99 s
I2 — delete NSG rule	3.73 s	5.04 s	7.05 s
Moyenne	2.73 s	4.02 s	6.02 s

Adéquation au modèle

Le modèle de H2 prédit `latency_min = 1 min` pour `wc_nsg`, soit 60 s. La réalité mesurée donne **4.02 s en moyenne**.

Résidu : -55.98 s.

L'écart est de **< 1 minute**, soit dans la tolérance attendue. Le modèle est **conservateur** : la latence réelle de propagation Azure→pipeline est **15× plus rapide** que la borne supérieure utilisée.

Conséquence : les valeurs M2.1, M2.2, M2.3 rapportées dans le présent rapport sont des **bornes supérieures** de ce que le pipeline produit en réalité. En production, la fraîcheur effective serait *meilleure*. Aucune révision des verdicts H2 n'est requise — au contraire, elle est renforcée.

Limites méthodologiques

Trois limites sont déclarées :

L-1 — Modèle déterministe sous-estime la variabilité réelle

Le modèle de cadences suppose des watchers fonctionnant nominalement. En production, des dégradations (lenteur API Azure, indisponibilité Wazuh, CI surchargé) peuvent **augmenter Δt** au-delà du modèle. Une calibration sur 1-2 mois de production réelle est recommandée pour validation externe.

L-2 — Catalogue à 8 catégories (équilibre artificiel)

Les 8 catégories ont été choisies *a priori* dans T-1.2. Dans un environnement réel, les CVE peuvent représenter > 60 % des événements (vs $1/8 = 12,5$ % ici). Le M2.1 réel dépend donc de la distribution effective des changements.

L-3 — Calibration pilote limitée à la catégorie C2 (NSG)

Une calibration pilote a été réalisée sur deux injections NSG réelles (cf. section précédente). Elle valide le modèle pour la catégorie C2 et démontre que les latences modélisées sont **conservatrices** par un facteur environ 15. Cependant, **les sept autres catégories** (C1 CVE, C3-C4 AD, C5 SIEM rule, C6 Docker, C7 SAST, C8 npm) **n'ont pas fait l'objet** de calibration empirique.

Une extension naturelle consiste à reproduire le protocole de calibration sur les autres catégories au cours des prochains cycles du pipeline.

| Reproductibilité

La mesure est reproductible avec `seed = 42` :

```
python validation/scripts/measure_h2.py
```

Les données brutes sont consignées dans `validation/results/h2_data.json` (24 lignes d'événements + statistiques) ; le protocole dans `validation/injection_protocol.yaml`.

| Conclusion

Le pipeline HOMO-CI, dans sa configuration de référence (régénération nightly à 22:00 UTC), atteint une **fraîcheur de propagation moyenne de 13.47 h** avec un **P95 de 22.83 h** et un taux de propagation à 24 heures de **100.0 %**.

Le facteur d'amélioration par rapport à la baseline manuelle (~90 jours) est de $\times 160$, ce qui démontre l'apport opérationnel central de l'approche d'homologation continue. **L'hypothèse H2 est confirmée** dans le cadre du modèle utilisé.

Mesure exécutée le 2026-05-15 14:23 UTC